Information Security CSC232

LECTURE-4 28-SEPT-2026

SAAD MALIK

Lecture Contents

Part 1: Introduction to Risk Management
- Relationship between Asset, Threat, Vulnerability, and Risk
- Risk Management Process
- Risk Identification, Assessment, Control Selection, and Monitoring

Part 2: Risk Assessment
- Asset Identification and Valuation
- Threat and Vulnerability Assessment
- Qualitative Risk Assessment and Risk Matrix
- Quantitative Risk Assessment
- SLE, ARO, ALE

Part 3: Risk Mitigation and Risk Response
- Risk Avoidance, Mitigation, Transfer, and Acceptance
- Administrative, Technical, and Physical Controls
- Preventive, Detective, and Corrective Controls
- Residual Risk

Part 4: Case Study & Discussion

Opening Scenario — Sequential Label and Supply (SLS)

Charlie Moody called the meeting to order...

"*Why is my department here?*" asked the manager of sales. "*Isn't security a problem for the IT department?*"

Charlie explained: "*We've come to realize that information security is about managing the risk of using information, which involves almost everyone in the company.*"

Key Point:
Risk management is not just an IT problem — it involves **all departments** and **all communities of interest**.

What is Risk Management?

Definition:
"Risk management is the process of identifying risk, as represented by vulnerabilities, to an organization's information assets and infrastructure, and taking steps to reduce this risk to an acceptable level."

Three Major Undertakings:

1. **Risk Identification** — Examination and documentation of the security posture
2. **Risk Assessment** — Determination of the extent to which assets are exposed or at risk
3. **Risk Control** — Application of controls to reduce risks

Sun Tzu's Wisdom:
"If you know the enemy and know yourself, you need not fear the result of a hundred battles."

- **Know Yourself** → Identify, examine, and understand your information and systems
- **Know the Enemy** → Identify, examine, and understand the threats facing the organization

The Relationship — Asset, Threat, Vulnerability, Risk

Concept	Definition	Example
Asset	Organizational resource being protected	Customer database, web server
Threat	Category of objects/persons that presents danger	Hackers, fires, malware
Vulnerability	Weakness that can be exploited	Unpatched software, weak passwords
Risk	Potential for loss when threat exploits vulnerability	Data breach, financial loss

Formula:
Risk = Threat × Vulnerability × Impact

Key Insight:
These concepts work together. You cannot manage risk without understanding all four.

The Risk Management Process

Three Core Components:



Continuous Process:
Risk management is **iterative** — not a one-time activity.

Roles of Communities of Interest

Community	Role in Risk Management
InfoSec Community	Best understands threats and attacks; takes leadership role
Management	Allocates resources (money, personnel); ensures security needs are met
Users	Work with systems and data; understand asset value; early detection
IT Community	Builds secure systems; operates them safely; provides valuation and threat perspectives

All Three Communities Must:

- Evaluate risk controls
- Determine cost-effective control options
- Acquire/install needed controls
- Ensure controls remain effective

Risk Identification — Overview

First Focus: Asset Inventory

- Verify completeness and accuracy regularly
- Review threats and vulnerabilities
- Review current controls and mitigation strategies
- Review cost effectiveness of each control
- Verify ongoing effectiveness of every control

Real-World Example:
A sales manager simulates a fire by clearing all desks before workday starts. Workers must follow disaster recovery procedures to assess effectiveness.

RISK ASSESSMENT

Risk Identification — Overview

Components of Risk Identification:

1. Plan and Organize the Process

- Organize a team with representatives from all affected groups
- Plan with periodic deliverables, reviews, and presentations
- Tasks laid out, assignments made, timetables discussed

2. Asset Identification and Inventory

- Enumerate all assets: people, procedures, data, software, hardware, networks
- Classify and categorize assets
- Establish relative priority to organizational success

3. Threat Identification and Prioritization

- Examine each threat's potential to endanger the organization
- Conduct threat assessment

Categorizing Information System Components

Traditional Components	Risk Management/SecSDLC Components
People	Employees (trusted, other staff), Nonemployees (contractors, strangers)
Procedures	IT and business standard procedures; IT and business sensitive procedures
Data	Transmission, Processing, Storage
Software	Applications, Operating systems, Security components
Hardware	System devices and peripherals; Security devices
Networking	Intranet components; Internet or DMZ components

Key Point:
Risk management categorization introduces **new subdivisions** that help identify assets more precisely.

Asset Identification — People, Procedures, Data

People:
- Position name/number/ID (avoid names; use roles/functions)
- Supervisor
- Security clearance level
- Special skills

Procedures:
- Description
- Intended purpose
- Relationship to software, hardware, networking elements
- Storage location for reference
- Storage location for update

Data:
- Classification
- Owner, creator, manager
- Size of data structure
- Data structure used (sequential or relational)
- Online or offline
- Location
- Backup procedures employed

Asset Identification — Hardware, Software, Network

Attributes to Track:

Attribute	Description	Example
Name	Most common device/program name	Server name (avoid CASH1, HQ_FINANCE)
IP Address	Useful for network devices (static IPs)	192.168.1.10
MAC Address	Unique hardware identifier	00:1A:2B:3C:4D:5E
Element Type	High-level and detailed classification	Server → Windows 2000 → Advanced Server
Serial Number	Unique device identifier	Manufacturer serial
Manufacturer	Device/software manufacturer	Dell, Microsoft
Model/Part Number	Exact model	PowerEdge R740
Software Version	Revision/FCO number	Windows Server 2019, BIOS v2.1
Physical Location	Where element is located	Data Center A, Rack 12
Logical Location	Network location	VLAN 10, DMZ
Controlling Entity	Organizational unit responsible	IT Operations, Network Team

Data Classification Schemes

Corporate Classification (3 levels):

Level	Description	Access
Confidential	Most sensitive; tightly controlled	Need-to-know basis
Internal	Internal information	Corporate employees, authorized contractors
External	Approved for public release	General public

Military Classification (5 levels):

1. **Unclassified** — Distributable to public
2. **Sensitive But Unclassified (SBU)** — For Official Use Only
3. **Confidential** — Could cause damage to national security
4. **Secret** — Could cause serious damage
5. **Top Secret** — Could cause exceptionally grave damage

Simple Organizational Scheme:

- **Public** — General dissemination
- **For Official Use Only** — Internal communications
- **Sensitive** — Could embarrass or cause loss of market share
- **Classified** — Utmost secrecy

Security Clearances & Management of Classified Data

Security Clearances:

- Each user assigned a single authorization level
- Based on role (data entry clerk, developer, analyst, CIO)
- Overriding clearance requires **need-to-know** standard

Management of Classified Data:

- **Storage:** Locked file cabinets, safes, protected systems
- **Distribution:** Clearly marked; color-coordinated cover sheets
- **Portability:** Inconspicuous (locked briefcase)
- **Destruction:** Shredding, burning, authorized document destruction
- **Clean Desk Policy:** Secure all information at end of day
- **Dumpster Diving:** Searching trash/recycling for information

Information Asset Valuation

Key Questions for Valuation:

1. Which asset is most critical to organizational success?
    - *Example:* Manufacturing company — process control systems are critical
    - *Example:* Amazon.com — web servers receiving orders are critical
2. Which asset generates the most revenue?
    - Evaluate how much revenue depends on a particular asset
3. Which asset generates the most profitability?
    - *Example:* Amazon sales servers vs. customer review database
4. Which asset would be most expensive to replace?
    - *Example:* Model-129 keypunch machine with no spare parts
5. Which asset would be most expensive to protect?
    - Cost of providing controls
6. Which asset would most expose the company to liability or embarrassment?
    - *Example:* Microsoft QAZ Trojan incident

Information Asset Prioritization — Weighted Factor Analysis

Example Worksheet:

Information Asset	Impact to Revenue (30)	Impact to Profitability (40)	Impact to Public Image (30)	Weighted Score
Customer order via SSL (inbound)	1.0	1.0	1.0	100
EDI Document Set 2 — Supplier orders (outbound)	0.8	0.9	0.6	78
EDI Document Set 1 — Logistics BOL (outbound)	0.8	0.9	0.5	75
Customer service request via email	0.4	0.4	0.9	55
EDI Document Set 2 — Supplier fulfillment advice	0.4	0.5	0.3	41

Process:

1. Assign weight to each critical factor (total = 100)
2. Score each asset (0.1 to 1.0)
3. Calculate weighted score
4. Prioritize assets based on score

Threat Assessment

14 General Threat Categories:

#	Category	Examples
1	Compromises to IP	Piracy, copyright infringement
2	Software Attacks	Viruses, worms, DoS
3	Deviations in QoS	ISP outages, power failures
4	Espionage/Trespass	Unauthorized access
5	Forces of Nature	Fire, flood, earthquake
6	Human Error	Accidents, mistakes
7	Information Extortion	Blackmail, disclosure
8	Missing Policy	No security policy
9	Missing Controls	No firewall
10	Sabotage/Vandalism	Destruction of systems
11	Theft	Equipment or data theft
12	Hardware Failures	Equipment failure
13	Software Failures	Bugs, code problems
14	Obsolescence	Outdated technology

Threat Assessment Questions

Four Key Questions:

1. Which threats present a danger to our assets in our environment?

- *Example:* Denver office on 12th floor → not subject to flooding
- *Example:* Oklahoma City office → not concerned with landslides

2. Which threats represent the most danger to our information?

- Probability of attack
- Amount of damage
- Frequency of attack
- Rate on scale of 1–5

3. How much would it cost to recover from a successful attack?

- Rough assessment of recovery costs
- Rate on scale of 1–5
- Or assign raw value ($5K, $10K, $2M)

4. Which threats would require the greatest expenditure to prevent?

- Cost of protection (malicious code = nominal; forces of nature = great)
- Rate effort/expense on scale of 1–5

Threat Assessment — CIO Rankings (2009 vs. 2003)

Threat Category	2009 Rank	2003 Rank
Espionage or trespass	1	4
Software attacks	2	1
Human error or failure	3	3
Missing/inadequate policy	4	—
Missing/inadequate controls	5	—
Theft	6	7
Compromises to IP	7	9
Sabotage/vandalism	8	5
Technical software failures	9	2
Technical hardware failures	10	6
Forces of nature	11	8
QoS deviations	12	10
Technological obsolescence	13	11
Information extortion	14	12

Key Insight: Espionage/trespass and software attacks are top concerns.

Vulnerability Assessment

Definition:
"A weakness or fault in a system or protection mechanism that opens it to attack or damage."

Types of Vulnerabilities:

Type	Example
Software	Unpatched operating system
Hardware	Unlocked server room door
Network	Open wireless access point
Human	Employee who shares passwords
Procedural	No backup system

Known vs. Unknown:

- **Known:** Documented and published vulnerabilities
- **Unknown (Zero-day):** Not yet discovered or patched

Real-World Example: Heartbleed (2014) — OpenSSL vulnerability exposed passwords, credit cards, private keys

Qualitative Risk Assessment

Definition:
Uses subjective judgment and experience to assess risk.

Risk Matrix Approach:

	Low Impact	Medium Impact	High Impact
High Probability	Medium	High	Critical
Medium Probability	Low	Medium	High
Low Probability	Low	Low	Medium

Advantages:

- Quick and easy to perform
- Doesn't require precise numerical data
- Good for initial assessment

Disadvantages:

- Subjective — different people may rate differently
- Less precise than quantitative methods

Quantitative Risk Assessment

Definition:
Uses numerical values and formulas to assess risk.

Key Formulas:

Single Loss Expectancy (SLE):
SLE = Asset Value × Exposure Factor

- **Asset Value:** Monetary value of the asset
- **Exposure Factor:** Percentage of asset lost in a single incident (0–100%)

Annualized Rate of Occurrence (ARO):
ARO = Number of incidents per year

Annualized Loss Expectancy (ALE):
ALE = SLE × ARO

Example Calculation:

- Asset Value: $100,000
- Exposure Factor: 50%
- SLE = $100,000 × 0.5 = $50,000
- ARO = 2 times per year
- ALE = $50,000 × 2 = $100,000 per year

Quantitative Risk Assessment — Example

Scenario: E-commerce Web Server

Factor	Value
Asset Value	$1,000,000
Threat	Hackers
Vulnerability	Unpatched server software
Exposure Factor	30%
SLE	$300,000
ARO	0.5 (once every 2 years)
ALE	$150,000

Control Decision:

- Cost of firewall solution: $50,000
- ALE without control: $150,000
- ALE with control: $30,000 (reduced risk)
- **Decision:** Implement the firewall (cost-effective)

Lesson: We invest in security controls when they are cheaper than potential losses.

Risk Assessment — Cost Benefit Analysis

Cost-Benefit Analysis Formula:
Cost-Benefit = ALE (before control) − ALE (after control) − Cost of Control

Example:
- ALE before control: $150,000
- ALE after control: $30,000
- Cost of control: $50,000
- **Cost-Benefit = $150,000 − $30,000 − $50,000 = $70,000**

Positive Result: Control is cost-effective.

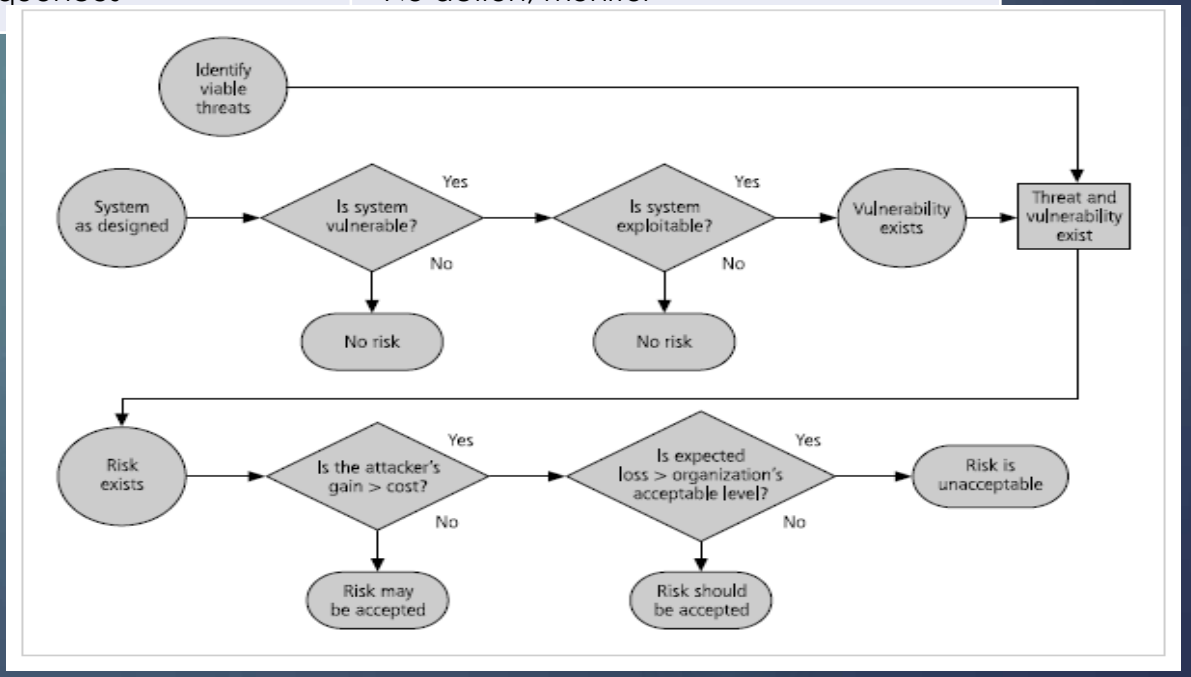
Key Point:
Organizations should only implement controls when the **benefit exceeds the cost**.

RISK MITIGATION AND RISK RESPONSE
Risk Control Strategies

Four Risk Control Strategies:

Strategy	Description	Example
Risk Avoidance	Eliminate the risk by not performing the activity	Discontinue a risky service
Risk Mitigation	Reduce the risk by implementing controls	Install firewall, encryption
Risk Transfer	Transfer the risk to another party	Buy insurance, outsource
Risk Acceptance	Accept the risk and its potential consequences	No action; monitor

Key Point:
Risk can **never be 100% eliminated**. Goal is to reduce risk to an **acceptable level**.



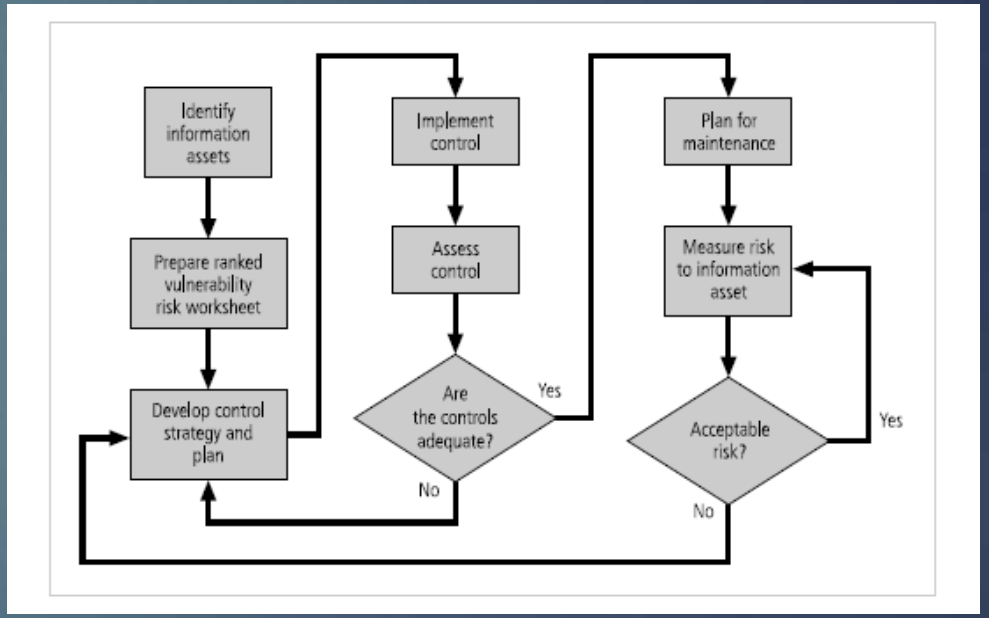
Risk Control Strategies — Detailed

Risk Avoidance:
- *"If you can't protect it, don't do it."*
- Example: A company decides not to store credit card numbers to avoid PCI compliance risk

Risk Mitigation:
- Most common strategy
- Implement controls to reduce vulnerability or impact
- Example: Install firewalls, IDPS, encryption, MFA

Risk Transfer:
- Purchase insurance
- Outsource risky operations
- Example: Cyber insurance, cloud provider security

Risk Acceptance:
- Accept that risk exists and do nothing
- Valid when: Cost of control > potential loss
- Example: Accept risk of minor website defacement



Classification by Control Function

Three Types of Controls by Function:

Type	Purpose	Examples
Preventive	Stop an incident from occurring	Firewalls, strong passwords, employee training, locks
Detective	Detect an incident after it occurs	IDS, security cameras, log monitoring, audits
Corrective	Correct or restore after an incident	Backups, disaster recovery, incident response

Key Point:
Effective security uses **all three types** in layers.

Real-World Example:

- **Preventive:** Firewall blocks unauthorized access
- **Detective:** IDS alerts on suspicious activity
- **Corrective:** Backup restores data after breach

Classification by Control Nature

Three Types of Controls by Nature:

Type	Description	Examples
Administrative	Policies, procedures, training	Security policy, awareness training, background checks
Technical	Technology-based controls	Firewalls, encryption, access control systems
Physical	Physical security measures	Locks, fences, guards, cameras, biometric scanners

Key Point:
All three types must work together for **Defense in Depth**.

Real-World Example — Target Breach (2013):

- **Administrative:** Third-party vendor had excessive access (missing separation of duties)
- **Technical:** Network not segmented (missing defense in depth)
- **Physical:** Not applicable in this case

Selecting Security Controls



Defense in Depth — Layered Controls

Concept:
Implement multiple layers of security controls so that the failure of one system does not compromise security.

Layers (Castle Approach):

Layer	Castle Equivalent	Network Equivalent
1	Moat	Perimeter firewall
2	Outer Wall	DMZ, IDPS
3	Inner Wall	Internal firewalls, segmentation
4	Keep	Host-based security, encryption
5	Guards	Security awareness, monitoring

Real-World Example — Target (2013):

- Layer 1: Firewall — Compromised via vendor credentials
- Layer 2: Network segmentation — Absent
- Layer 3: IDPS — Alerts ignored
- Layer 4: Data encryption — Not implemented at rest
- **Result:** 40 million records stolen

Security Controls — Examples by Category

Key Point:
Controls are not mutually exclusive — a single control can serve multiple functions.

Control Type	Preventive	Detective	Corrective
Administrative	Security policy, training, background checks	Audits, reviews, mandatory vacations	Incident response plan, business continuity
Technical	Firewalls, encryption, MFA, access control	IDS, SIEM, log monitoring, antivirus	Backups, patch management, disaster recovery
Physical	Locks, fences, guards, biometrics	CCTV, motion sensors, alarms	Fire suppression, UPS, redundant systems

Maintaining and Perpetuating Controls

Ongoing Activities:

1. **Periodic Management Reviews**
    - Verify asset inventory completeness
    - Review threats and vulnerabilities
    - Review current controls and mitigation strategies
    - Review cost effectiveness of each control

2. Continuous Monitoring
- Monitor for new vulnerabilities
- Monitor for new threats
- Monitor control effectiveness

3. Regular Updates
- Patch management
- Policy updates
- Training refreshers

Real-World Example:
Equifax Breach (2017) — Procedures for patching known vulnerabilities were not followed. Apache Struts vulnerability identified in March 2017; patch available but not applied. Cost: $1.4 billion+.

Risk Appetite & Residual Risk

Risk appetite defines the quantity and nature of risk that organizations are willing to accept as they evaluate the tradeoffs between perfect security and unlimited accessibility

Residual Risk is the risk that remains after controls have been implemented."

Formula:

Residual Risk = Total Risk − Controls Implemented

Key Points:

- Risk can never be 100% eliminated
- Goal is to reduce risk to an **acceptable level**
- Residual risk must be **documented and accepted** by management

Example:

- Total Risk (ALE): $150,000
- Controls Implemented: Firewall, encryption, MFA
- Reduced Risk (ALE): $30,000
- **Residual Risk:** $30,000

Management Decision: Accept residual risk or implement additional controls.

Risk Response — Decision Matrix

Risk Level	Recommended Response	Example
Critical	Avoid or Mitigate immediately	Stop activity or implement controls
High	Mitigate or Transfer	Implement controls or buy insurance
Medium	Mitigate or Accept	Implement cost-effective controls
Low	Accept	Monitor; no action needed

Key Point:
The response depends on the **cost-benefit analysis** of each control.

Real-World Risk Management Failures

Case 1: Equifax (2017)

- **Asset:** 147 million consumer records
- **Threat:** Hackers
- **Vulnerability:** Unpatched Apache Struts
- **Root Cause:** Procedures not followed
- **Cost:** $1.4 billion+

Case 2: Target (2013)

- **Asset:** 40 million credit card numbers
- **Threat:** Hackers via HVAC vendor
- **Vulnerability:** No network segmentation; excessive vendor privileges
- **Cost:** $18.5 million settlement + reputation damage

Case 3: Colonial Pipeline (2021)

- **Asset:** Pipeline operations
- **Threat:** Ransomware (DarkSide)
- **Vulnerability:** Compromised VPN password; no MFA
- **Cost:** $4.4 million ransom + fuel shortage

Lesson: Risk management failures have real, significant consequences.

Case Study — SLS Risk Management Task Force

Scenario:
Sequential Label and Supply (SLS) has formed an Information Security Task Force to identify and classify IT risks.

Charlie Moody's Team Must:
1. Identify all information assets
2. Classify assets by sensitivity
3. Identify threats to each asset
4. Assess vulnerabilities
5. Calculate risk (probability × impact)
6. Select controls (cost-benefit analysis)
7. Monitor and maintain controls

Discussion Questions:
1. Why is sales department involved in security?
2. How would you prioritize SLS's assets?
3. What threats are most relevant to SLS?
4. What controls would you recommend?

Thank you